

Seguridad

- ↳ 0 confía en frontend (nunca chequear en backend)
- ↳ conviene usar mínimo
 ↗ STACK FE/BE
- ↳ doble validación

FRONTEND DIRECTO A DB

- (min backend)
- ↳ se puede implementar la seguridad necesaria en DB.

Lenguaje SQL

clasificación principal

DDL
definition
CREATE TABLE
ALTER
DROP
TRUNCATE

DML
manipulation
SELECT
INSERT
UPDATE
DELETE
TRUNCATE

clasificación extendida

DCL
data control

GRANT
REVOKE

TCL
task control

BEGIN TX
COMMIT
ROLLBACK

TRANSACTIONS → solo se pueden hacer DML (entonces)

↳ Emilio → si hay DDL → abort

ORACLE → ① → commit

POSTGRES → ② → inter-transaction

Ley de Datos Personales (! no el final)

→ distinguir $\neq$ dato personal
vs
sensible

→ prohibido → pedir datos
que empresa
no necesita

↓
no datos tienen tiempo de
ser vulnerados
→ riesgo a la persona.

→ derecho a conocer y remover
toda la información
almacenada x empresa

Aspectos de Seguridad

- Integridad (permisos / write) → modo de copiar de modificar datos
- Confidencialidad (permisos / read) → no lectura
- Disponibilidad → DDOS

Tipos de seg

↳ Físico

↳ Lógico

↳ Administrativo (procedimientos)

Problema → Colaciones
Seguridad y Confidencialidad

CREATE ROLE name [(WITH)option(s)]

where option can be

SUPERUSER | NO SUPERUSER

: ⊕ other roles / restrictions

en postgres: rol = usuario

C/ usuario debe tener mínimo permisos p/ realizar tareas

↳ en caso de excepciones debe pedir acceso explícitamente

en DB

↳ debe haber 2 usuarios

✗ mínimo de usuarios

→ DUEÑO de DB → modificación y manejo DB (DDL)

→ usuario p/ DML

→ puede haber

↳ 1 usuario x d
usuario físico
1 usuario x rol

GRANT {privileges} ON {table}
TO {role} [(WITH GRANT OPTION)]

↓
permite comparación
ocurrencias

↳ se puede granular x columna, base de datos, esquemas, funciones y procedimientos

↳ pueden córrer con permisos SUDO (creator) o CALLER

También se puede permisionar permisos

También permisos por fila

↳ CREATE POLICY fp_s ON information FOR SELECT USING (level <= (SELECT level FROM users WHERE user_name = current_user))

Quitar permisos → REVOKE

IMMUTABLE → doesn't depend on values of DATABASE

STABLE → depends on values of tables but doesn't alter them

VOLATILE → ~ IMM, ~ STABLE

Inyección de código

↳ divulgar código en una variable



↳ envío fijo reponido de variable

⊕

sanitización/quoting

↳ ¡ punto de contacto c/ otros sistemas